

Authorisation, MFA & Least Privilege



Session 5 - Completing the IAM Layer



S5 Authorisation, MFA & Least Privilege

Completing the IAM layer: from who you are to what you can do



Session 5 Overview

From 'who' to 'what' - completing the IAM layer

- LO1 - Evaluate authorisation and MFA mechanisms for a given set of requirements
- LO2 - Use least-privilege and accountability analysis to evaluate a system's access-control security



The IAM Journey So Far



Foundation

S3

Cryptography

Gives us the properties: confidentiality (encrypt), integrity (hash), authenticity (sign / certify).

Identity

S4

Authentication

Proves identity: passwords, sessions, tokens. Establishes who is asking.

Access - Today

S5

Authorisation

Controls access once identity is known: RBAC / ABAC, least privilege, MFA. Completes IAM.

From 'Who Are You' to 'What Can You Do'



- **Authentication (S4):** who is asking - passwords, sessions and tokens confirm identity.
- **Authorisation (S5):** what they can do - RBAC, ABAC and least privilege decide access once identity is known.

Analogy

A hotel front desk checks your photo ID before handing over a room key (Authentication). The key itself only opens your room, not every room in the hotel, and not the manager's office (Authorisation). Front desk could verify your ID perfectly and still hand you the wrong key.

KEY CONCEPT

AuthN and AuthZ Fail Independently

- A system can authenticate correctly and still authorise wrong - an IDOR reaches someone else's record.
- A system can authorise correctly and still authenticate weakly - a stolen password walks straight through both checks.
- One breaks Confidentiality or Integrity. The other breaks Authenticity itself - and takes Authorisation down with it.



One SRS, Two Separate Controls



- **IAM-01 tests authentication: does the system correctly verify identity? (MFA, session integrity - S4)**
- **IAM-02 tests authorisation: does the system correctly restrict what a verified identity can reach? (RBAC / ABAC - this session)**
- **Both need their own acceptance test. A requirement that only checks login is not a requirement about access.**

Coursework hook: Feeds Part A's mini-SRS and Part B2 (identity, authn/z, secrets) - IAM-02 becomes writable from here.

RBAC and ABAC: Two Ways to Decide Access



- **RBAC - Role-Based Access Control:** permissions attach to a role, roles attach to users. Simple, auditable.
- **ABAC - Attribute-Based Access Control:** permissions depend on attributes of user, resource and environment. Finer-grained.

Analogy

RBAC is like a staff badge that says 'Nurse' - it opens every nurse door, nothing more, nothing less. ABAC is like a smart badge that also checks the time of day, which ward you're standing in, and whether the patient is currently assigned to you before it decides.

RBAC vs ABAC: A Design Trade-Off

RBAC

Simple & Auditable

- + Easy to review - a role list shows exactly what a user can do.
- + Fast to implement and explain in a viva.
- - Coarse-grained - can't express "only during business hours" or "only your own records."

ABAC

Fine-Grained & Flexible

- + Expresses context: time, location, ownership, resource sensitivity.
- + Matches complex real systems (healthcare, banking).
- - Harder to audit - the rule set itself becomes something to secure and review.

Coursework hook: Neither is always correct - the choice is a design decision that belongs in your SRS. State which model, and why, for your assigned domain.

Least Privilege: Minimum Access Required



- **Every identity - human or service - should hold only the permissions its function actually requires.**
- **Not "might need someday." Not "easier to just grant admin." The minimum, for exactly as long as it's needed.**

Analogy

A hotel cleaner's keycard opens the rooms on their floor, for their shift - not the safe, not every floor, not after checkout. Give someone the master key because it's convenient, and you've traded a small operational saving for a large security cost.

Where Least Privilege Breaks Down



- **Overpermissioned service accounts** - an automated process granted admin rights it will use maybe once, forever.
- **Shared administrative credentials** - one login, many hands; convenient to set up, impossible to attribute.
- **Privilege creep** - permissions accumulate as people change roles, and nobody revokes the old ones.

Coursework hook: Each pattern is a testable SRS finding: no shared admin accounts; service accounts scoped to minimum required calls; quarterly access review.

KEY CONCEPT

One Failure, Two Properties

- A shared admin account performs a destructive action. Which entity acted? Nobody can say - an Authenticity failure.
 - Can anyone be held to it? No - an Accountability failure, at the same moment, from the same gap.
 - This is what S2 called Elevation of Privilege: unable to prove which identity escalated, or that it happened at all. Least privilege and individual accountability are inseparable.
-

The Accountability Requirement



- IAM's accountability requirement, written into the SRS: "All privileged actions must be logged with authenticated user identity, timestamp and action detail."
- No shared account can satisfy this requirement by construction - which is exactly the point.

Coursework hook: Completes the IAM accountability control - feeds B2 (identity, authn/z, secrets) and B6 (observability, S11).

MFA Methods: A Comparison



Widely Supported

TOTP

Time-based one-time code

- Low cost, widely supported.
- Phishable in real time - a fake login page can relay the code instantly.

Convenient

PUSH

Push notification

- Convenient, one tap.
- Vulnerable to MFA fatigue - repeated prompts until someone taps approve.

Strongest

FIDO2

Hardware security key

- Strongest - resistant to phishing and relay.
- Higher cost and friction to deploy at scale.

MFA Fatigue: A Current, Live Attack



- **Mechanism:** an attacker who already has a stolen password triggers repeated push notifications, once a minute, for hours.
- **Goal:** exhaustion, not cleverness. Eventually someone taps 'Approve' just to make the notifications stop.
- **Failure:** MFA was correctly deployed. The human step broke Authenticity anyway - possession of the second factor got reduced to "whoever is annoyed enough to say yes."

Coursework hook: A live SRS consideration, not a historical vulnerability - number-matching or hardware-key rules are testable IAM-01 mitigations.

Is This a Live Threat for Your Domain?

MFA fatigue attacks are already targeting healthcare and banking systems. For your assigned coursework domain - is push-based MFA a live risk, or would a hardware key or number-matching requirement be justified? What would you write into IAM-01?

Writing the MFA Requirement



- **IAM-01 (extended): "All administrative accounts must require MFA resistant to fatigue attacks (number-matching or hardware key)."**
- **Acceptance test: trigger repeated push approvals without number-matching confirmation - the login must not succeed.**

Coursework hook: Distinguishing 'MFA is present' from 'MFA is fatigue-resistant' is exactly the evaluative judgement Part B rewards.

Anatomy of a Testable SRS Requirement



- **ID** - a short label you can reference later (e.g. IAM-02).
- **Statement** - the control itself, specific enough that two people would implement it the same way.
- **Acceptance test** - how someone (including your viva examiner) verifies it: 'attempt X, expect Y.'

Coursework hook: This is the exact shape every finding in the Activity must take - draft ID, statement and acceptance test for each one.

Activity: Spot the Gaps

Given a user-role matrix for a fictional system:

- 1. Identify accounts that violate least privilege
- 2. Find privilege escalation paths - where can a lower-privileged account reach higher-privilege resources?



Activity: Draft the SRS

- 3. Identify roles that would make Accountability impossible (shared accounts, generic roles)
- 4. For each finding, draft a testable SRS requirement with an acceptance criterion

Structured tabular analysis - no code.



Try It: Role-Permission Matrix



- **Open NB5004CEM_S5_Authorisation_Demo_RoleMatrix.html on your own device - double-click, works offline.**
- **Build a small role-permission grid, then toggle permissions on and off.**
- **Watch the tool flag least-privilege violations and highlight escalation paths live - the same judgement you just made by hand, now visualised.**

Naming the Category (Lightly)



- What you'll find in the Lab is a form of broken access control - the system trusted a value from the URL without checking who it belonged to.
- For now, just name it in plain English and cite the evidence. The full OWASP Top 10 taxonomy - including where this sits formally - arrives in Session 6.

Coursework hook: Keeps your finding format Session-6-ready: title, evidence, property violated, SRS mapping - without needing the framework yet.

Lab: Find the IDOR

DVWA (browser only): IDOR exercise
- access a record belonging to another user by manipulating a URL parameter.

- **Observe the failure**
- **Document what access control check was missing**



Lab: Report the Finding

- Map to the correct OWASP category
- Write the SRS requirement that would have prevented it, with an acceptance test



IAM Layer Complete

IAM-01

MFA for admins

Authentication - S4

IAM-02

RBAC / ABAC access

Authorisation - S5

LOG

Privileged action logging

Accountability - S5

IAM Element	Status After S5
Authentication (S4)	Established - passwords, sessions, tokens
Authorisation (S5)	Established - RBAC / ABAC, least privilege
MFA method choice	Established - TOTP / Push / FIDO2 trade-off
Accountability logging	Established - privileged actions traceable
IAM Layer	COMPLETE - all requirements writable

What S5 Paid Back to S1



- **S1 introduced Accountability as a property CIA alone would miss. S5 is where it earns its keep: the shared-admin-account failure (Crux 2) is the clearest example in the module of one real failure violating two properties at once.**
- **S2's STRIDE mapped Elevation of Privilege to Authenticity + Accountability. The IDOR lab and the escalation-finder demo are that mapping, made concrete and hands-on.**
- **Five layers, five properties, one coherent evaluation lens - carried forward into S6 (Application) and beyond.**

Questions & Discussion

Next: Session 6 - Application Security & the OWASP Top 10



Disclaimer & Copyrights



The information presented in this presentation is intended for general informational purposes only. It is not meant to be comprehensive or to constitute professional advice. Any reliance you place on such information is strictly at your own risk. While I strive to keep the information accurate and up-to-date, I make no representations or warranties of any kind, express or implied, about the completeness, accuracy, reliability, suitability, or availability concerning the content within this presentation.

This presentation may include references or links to third-party websites or content. I do not endorse the views expressed or the information provided on such external sites. I am not responsible for the content of any linked site or any link contained in a linked site.

Any action you take upon the information presented in this presentation is strictly at your own discretion. I will not be liable for any losses or damages in connection with the use of this information.

This disclaimer is subject to change without notice.

@ Images and artworks used in this presentation are used for general informational purposes only. It may contain copyrighted material, the use of which may not have been specifically authorised by the copyright owner. This material is available in an effort to explain issues relevant to the topic. This should constitute a 'fair use' of any such copyrighted material.

Last modified: 2 Jul 2026